Security Awareness Guide & Baseline Security Policy

Applies to Linux (Ubuntu, Kali) and Windows workstations and servers in scope of the project.

Part A - Security Awareness Guide (for all team members)

Core rules

1. **Least privilege:** use a standard account day to day; elevate (sudo / "Run as administrator") only for the task that needs it.
2. **Strong authentication:** unique passwords of 14+ characters from a password manager; MFA wherever available. Never share accounts.
3. **Phishing awareness:** check sender, links and attachments; report suspicious mail with the "Report phishing" button or to the security mailbox. Do not click first, ask second.
4. **Lock and update:** lock screen when away (Win+L / Super+L); install OS and application updates within the patch window.
5. **Data handling:** classify data (Public / Internal / Confidential); store Confidential data only on approved, encrypted locations; never paste secrets or credentials into tickets or chats.
6. **Report fast:** any suspected incident (lost device, odd login, malware warning) is reported within 1 hour; reporting is never punished.
7. **Kali caution:** Kali Linux is for authorized testing only. Use it on isolated lab networks or with written authorization, never as a daily-use workstation or on production systems without approval.

Quick red flags

Sign	Action
Unexpected password-reset email	Do not click; report; change password via official site
Pop-up asking to install software	Close; open a ticket
Colleague asks for credentials	Refuse; verify by phone; report
Repeated failed logins on your account	Report to security (possible brute force)

Training plan

- 60-minute session in Week 3 (Day 15) with short quiz (target pass mark 80%).
- Phishing simulation: baseline before training (Week 3, Day 11), follow-up after training (Week 4, Day 19), then quarterly.
- Monthly 10-minute micro-reminders.

Part B - Baseline Security Policy

B1. Access Control (both platforms)

Control	Requirement

Accounts	Named individual accounts only; shared/generic accounts prohibited except documented service accounts
Privilege	Admin rights by approval; reviewed monthly; remove on role change/leave
Passwords	Min 14 chars, no reuse of last 10, lockout after 5 failed attempts
MFA	Required for remote access, admin accounts and email
Joiner/Mover/Leaver	Access granted via ticket, removed within 24 hours of leaving
Dormant accounts	Disable accounts with no login for 90 days (the automation script flags the same 90-day threshold)
Review	Quarterly user-access review against the approved access list

B2. Linux (Ubuntu / Kali) Hardening Checklist

#	Control	How to apply / verify
L1	Keep system patched	`sudo apt update && sudo apt upgrade`; enable `unattended-upgrades`
L2	Disable root SSH login, use key authentication	`/etc/ssh/sshd_config`: `PermitRootLogin no`, `PasswordAuthentication no`, `MaxAuthTries 3`
L3	Firewall default deny	`sudo ufw default deny incoming && sudo ufw allow ssh && sudo ufw enable`
L4	Minimal services	`systemctl list-unit-files --state=enabled`; disable unused (e.g. telnet, ftp)
L5	Least-privilege sudo	Review `/etc/sudoers` and `/etc/sudoers.d/`; no `NOPASSWD: ALL` for users
L6	Password quality, history and lockout	PAM `pam_pwquality` (`minlen=14`), `pam_pwhistory` (`remember=10`), `pam_faillock` with `deny=5` (or `pam_tally2` on older systems)
L7	File permissions	No world-writable files in system dirs: `find / -xdev -type f -perm -0002 2>/dev/null`
L8	Logging and audit	Ensure `rsyslog`/`journald` persistent; install `auditd`; forward logs centrally
L9	Brute-force protection	Install `fail2ban` for sshd
L10	Disk encryption	LUKS on laptops and portable devices
L11	Lynis audit	`sudo lynis audit system` monthly; track hardening index
L12	MFA for remote and admin access	SSH with key plus second factor (`libpam-google-authenticator` via `AuthenticationMethods publickey,keyboard-interactive`, or FIDO2 `sk-` keys); verify with `sshd -T | grep -i authenticationmethods`

Kali-specific: disable default credentials (kali/kali), do not expose services (e.g. SSH) to untrusted networks, run as non-root user (default since 2020.1), keep tools updated and isolated in a VM/lab.

B3. Windows Hardening Checklist

#	Control	How to apply / verify
W1	Patching	Windows Update / WSUS; critical patches within 14 days

W2	Local admin control	Remove users from Administrators group; use LAPS for local admin passwords
W3	Password, history & lockout policy	GPO: Account Policies -> Password Policy (minimum length 14, **Enforce password history: 10**) and Account Lockout Policy (5 attempts, 15 min)
W4	Disk encryption	BitLocker enabled; recovery keys stored in AD/Entra
W5	Endpoint protection	Microsoft Defender on, real-time protection and cloud protection enabled
W6	Firewall	Windows Defender Firewall on for all profiles
W7	Disable legacy protocols	Disable SMBv1, NTLMv1; restrict RDP with NLA and MFA/VPN
W8	Audit policy	Enable auditing: logon events (4624/4625), account management (4720/4726/4732), policy change
W9	Application control	Restrict macros from the internet; block executables from temp directories where feasible
W10	Verification	Microsoft Security Compliance Toolkit / `Get-MpComputerStatus`, `Get-LocalGroupMember Administrators`
W11	MFA for remote and admin access	MFA enforced for VPN/RDP gateway, Microsoft 365/Entra sign-in and all administrator accounts; verify in the identity provider's MFA registration report

B4. Policy Compliance

- Baseline owner: Security lead; exceptions need written approval, a reason and an expiry date.
- **Scoring method:** a host *passes* only if every Critical and High control passes. Critical/High controls: Linux L1, L2, L3, L5, L6, L9, L12; Windows W1, W2, W3, W5, W6, W7, W11. Other controls are Medium and tracked but do not decide pass/fail.
- **Compliance %** = passing hosts / all in-scope hosts. Hosts with an approved, time-limited exception are listed separately and not counted as passing. Target 90% by end of Week 4, 95% thereafter.
- Non-compliance creates a ticket with severity and due date (Critical 7 days, High 14, Medium 30).

B5. Routine Security Audit Schedule

Frequency	Activity	Owner
Daily	Run log-parsing script; review failed logins, sudo use, new accounts	Sysadmin on duty
Weekly	Review privileged group changes; check patch status; review open vulnerabilities	Sysadmin
Monthly	Lynis / Windows baseline scan; review Admin and sudoers lists	Security
Quarterly	Full user-access review; backup restore test; awareness refresher; policy review	Security + Manager
After incident	Post-incident review and baseline update	Security lead

B6. Logging & Retention

- **Retention:** authentication and admin-activity logs at least 90 days online (12 months archived where required). The analyzer database keeps event history for the same 90 days (`--retention-days`).
- **Central forwarding:** hosts forward auth and audit logs (rsyslog over TLS, or the Windows Event Forwarding equivalent) to one designated log host. The sponsor designates the log host in Week 1; until it exists, local logs are retained on each host and copied weekly by the sysadmin.
- **Archive custody:** the Security lead is the custodian of archived logs. Archives are stored on write-once or access-restricted storage, readable only by Security and the sysadmin on duty, with a SHA-256 checksum recorded for each archive file; any access to archives is logged.
- **Report handling:** analyzer outputs contain account names and source addresses; they are stored in an owner-only folder (the script creates it with mode 0700) and shared only with the team.
- **Integrity:** logs are protected from modification, and time is synchronized (NTP) on all hosts.